

INGETIS

Ecole d'ingénierie informatique — 62 bis rue Gay-Lussac, 75005 Paris
EASRSI - RNCP38823

DOSSIER PROFESSIONNEL

Soutenance de certification RNCP Niveau 7

BLOC 1 — PHASE DE CADRAGE ET DE CONCEPTION DU PROJET ECOTRACK

Spécialité : Cybersécurité et Réseaux

Candidat(e) : _____ **SIDIBE_SALIH** _____

Numéro apprenant : _____ **07_45_35_00_06** _____

Année : 2025-2026

Date de soutenance : _29_ / _06_ / _2026_

*Soutenance : 20 min de présentation + 20 min d'entretien avec le jury
Document confidentiel — INGETIS 2025-2026 — Usage académique strictement réservé*

SOMMAIRE

SOMMAIRE	1
CHAPITRE 1 : Étude de faisabilité	2
1. Contexte stratégique et enjeux du projet ECOTRACK	2
2. Faisabilité technique du projet Ecotrack	3
3. Faisabilité économique et ROI.....	6
4. Faisabilité opérationnelle — organisation agile scrum	7
Conclusion et recommandations	8
CHAPITRE 2 : Veille technologique	9
5. Méthodologie de veille technologique	9
6. Comparaison des technologies	9
7. Technologies complémentaires	12
8. Choix technologiques finaux.....	13
9. Stack technique complete.....	14
CHAPITRE 3 : Architecture technique déployée	15
10. Vision globale de l'architecture	15
11. Mesures de sécurité et conformité.....	16
CHAPITRE 4 : Modélisation BPMN des Flux.....	19
12. Modélisation BPMN	19
CHAPITRE 5 : Audit initial et plan de continuité.....	22
13. Audit initial de l'infrastructure	22
14. Plan de Continuite et de Reprise d'Activité (PCA/PRA)	24
Conclusion Générale	26
Table des matières.....	28

CHAPITRE 1 : Étude de faisabilité

1. Contexte stratégique et enjeux du projet ECOTRACK

La gestion des déchets urbains constitue aujourd'hui un enjeu hautement stratégique pour les métropoles contemporaines en pleine expansion. Face à l'urbanisation croissante, à la densification des centres-villes et aux impératifs environnementaux dictés par la transition écologique, les collectivités territoriales se trouvent dans l'obligation de moderniser leurs infrastructures logistiques. Les méthodes traditionnelles ne permettent plus de répondre efficacement aux exigences citoyennes ni aux réglementations environnementales strictes, ce qui pousse les municipalités à rechercher des solutions innovantes capables de rendre les services de salubrité publique à la fois plus efficaces, écologiques et économiquement viables à long terme.

Le projet **EcoTrack** s'inscrit directement dans cette démarche de transformation numérique en proposant une infrastructure logicielle et matérielle unifiée de pointe. En combinant l'Internet des Objets (IoT), les architectures de réseaux distribués et des protocoles de cybersécurité avancés, EcoTrack ambitionne de remplacer les processus empiriques par un pilotage intelligent et transparent. Cette plateforme industrielle permet une supervision en temps réel des conteneurs de déchets urbains, garantissant une réactivité opérationnelle maximale tout en protégeant l'intégrité des systèmes d'information de la ville face aux menaces numériques émergentes.

1.1. Problématique actuelle et inefficacités structurelles

1.1.1. Logistique empirique et inefficacité des collectes

Les systèmes de ramassage traditionnels souffrent d'un manque critique de visibilité opérationnelle qui pénalise l'ensemble de la chaîne de valeur. Les équipes de terrain effectuent quotidiennement des passages inutiles sur des conteneurs à moitié vides, tandis que d'autres secteurs subissent des débordements fréquents dans les zones à forte densité urbaine, créant des risques sanitaires et des nuisances visuelles majeures pour les administrés. Cette absence de données en temps réel interdit toute flexibilité et condamne la municipalité à subir le rythme de l'espace urbain plutôt que de le piloter.

1.1.2. Surcoûts financiers et dérive budgétaire

L'absence d'optimisation engendre des coûts opérationnels excessivement élevés qui pèsent lourdement sur les budgets des collectivités territoriales. Les kilomètres excédentaires parcourus par des flottes de camions lourds font grimper en flèche les dépenses directes liées au carburant, à la main-d'œuvre et à la maintenance prématurée des véhicules de collecte. De plus, la planification des tournées reste archaïque, s'appuyant sur des calendriers fixes et des grilles horaires rigides qui ne tiennent jamais compte des variations saisonnières ou des pics d'utilisation locaux.

1.1.3. Impact environnemental et faille de sécurité

Sur le plan écologique, la rotation de véhicules non optimisés génère un impact environnemental significatif, caractérisé par des émissions massives de gaz à effet de serre (Dioxyde de Carbone), ainsi qu'une pollution sonore et atmosphérique néfaste pour la santé publique. À cette dette environnementale s'ajoute un manque flagrant de données analytiques consolidées, empêchant les gestionnaires de mesurer précisément la performance du service ou de planifier des améliorations basées sur des faits. Enfin, l'introduction récente de technologies

connectées sans gouvernance expose la ville à de graves vulnérabilités de sécurité, les infrastructures IoT non protégées devenant des portes d'entrée idéales pour des cyberattaques malveillantes.

1.2. Objectifs stratégiques et trajectoire de transformation

1.2.1. Numérisation et connectivité IoT

Le premier pilier du projet consiste à déployer une flotte massive de capteurs connectés robustes directement sur les conteneurs urbains afin de collecter les données de niveau de remplissage. Ces modules IoT transmettront de manière transparente et continue l'état des bacs vers une passerelle centralisée, permettant de cartographier la situation à l'échelle de l'agglomération (500 000 habitants). Cette couche de connectivité est essentielle pour briser l'asymétrie d'information actuelle et construire le jumeau numérique de la gestion des déchets de la métropole.

1.2.2. Sécurisation de l'infrastructure et défense en profondeur

Face aux menaces de cyberattaques, EcoTrack place la protection des systèmes au cœur de son architecture via une stratégie de sécurité native (*Security by Design*). Cet axe impose le chiffrement de bout en bout de l'ensemble des communications (notamment via le protocole TLS 1.3), le durcissement des micro services applicatifs et la mise en conformité stricte avec les directives de l'ANSSI et du RGPD. En isolant les flux IoT des données nominatives des agents, la plateforme garantit la résilience de cette infrastructure devenue d'importance vitale pour la municipalité.

1.2.3. Optimisation opérationnelle et planification dynamique

L'objectif économique et logistique majeur consiste à réduire immédiatement les coûts d'exploitation directs de **20% à 30%** dès les premières phases du déploiement. Pour y parvenir, EcoTrack intègre un moteur d'optimisation basé sur un algorithme de résolution du problème du voyageur de commerce (TSP) sous contraintes géospatiales. Les tournées ne seront plus fixes mais recalculées dynamiquement chaque jour, orientant les camions uniquement vers les conteneurs ayant atteint un seuil critique de remplissage, éliminant ainsi les trajets superflus.

1.2.4. Pilotage par la donnée et aide à la décision

Enfin, le projet vise à instaurer une véritable culture de la donnée au sein des services d'ingénierie urbaine en fournissant des outils décisionnels et analytiques de haut niveau. Les gestionnaires de la métropole disposeront de tableaux de bord de supervision mis à jour en continu, avec une latence d'ingestion des messages IoT inférieure à **2 secondes**. Ces indicateurs de performance clés (KPIs) standardisés permettront non seulement de piloter l'activité au quotidien, mais aussi d'anticiper les comportements futurs grâce à l'analyse historique des flux de déchets.

2. Faisabilité technique du projet Ecotrack

La faisabilité technique du projet EcoTrack repose sur la mise en œuvre d'une architecture réseau multicouches hautement résiliente, associée à un stack de sécurité éprouvée et un système de monitoring global. L'ensemble des composants applicatifs et d'infrastructure a été conçu selon les principes fondamentaux de la haute disponibilité, de la tolérance aux pannes et de la défense en profondeur. Cette synergie technologique permet d'absorber la charge critique

générée par les 180 millions de mesures annuelles issues des capteurs IoT, tout en garantissant un niveau d'intégrité et de confidentialité maximal pour les données de la métropole.

2.1. Architecture réseaux segmentée

L'infrastructure réseau globale est rigoureusement segmentée en cinq zones distinctes et hermétiques, chacune répondant à une fonction opérationnelle spécifique. Cette compartimentation stricte est orchestrée par des politiques de filtrage bidirectionnelles appliquées aux pare-feux, garantissant qu'une éventuelle compromission au sein d'une zone ne puisse pas se propager de manière latérale aux autres pans du système, limitant ainsi drastiquement la surface d'attaque globale.

Zone	Rôle	Composants principaux	Niveau de sécurité
WAN	Accès externe / Internet	Connexion opérateur, VPN entrant	Périmètre — filtre maximum
DMZ	Zone de transit sécurisée	Load Balancer, HAProxy, Reverse Proxy Nginx	Haute — filtrage bicéphale
APPLICATIF	Services métier	Site Web, Base de données PostgreSQL	Haute — accès contrôle
MANAGEMENT	Supervision et sécurité	Wazuh, Prometheus, Grafana, ELK Stack	Maximale — accès restreint
IoT	Capteurs terrain	Service Mosquitto MQTT, Scripts de simulation	Isolée — protocole dédiée

2.2. Stack de sécurité réseaux et système

Le stack de sécurité d'Ecotrack est constituée exclusivement de solutions open-source matures, performantes et complémentaires, sélectionnées pour leur capacité à s'intégrer nativement au sein d'environnements virtualisés. Cette alliance logicielle permet d'établir une surveillance continue aux niveaux réseau et applicatif, garantissant une détection précoce des anomalies et une neutralisation automatisée des menaces avant qu'elles n'impactent la production.

Composant	Technologie	Rôle dans l'architecture
Pare-feu périmètre	pfSense	Filtrage stateful, gestion des règles NAT/ACL, VPN IPsec/OpenVPN
Détection d'intrusion	Suricata (IDS/IPS)	Analyse du trafic réseau en temps réel, détection et blocage des menaces
SIEM / HIDS	Wazuh	Collecte et corrélation des événements de sécurité, détection d'anomalies hôte
Reverse Proxy / WAF	Nginx + Mod Security	Filtrage des requêtes HTTP/S, protection contre les injections et attaques web

Composant	Technologie	Rôle dans l'architecture
Threat Intelligence	VirusTotal (integr. Wazuh)	Enrichissement CTI : analyse des IOC, hashes, IP et URLs suspectes

2.3. Monitoring avancé et supervision multi-dimensions

Le système de monitoring d'EcoTrack est structuré comme un observatoire global et tridimensionnel de l'infrastructure, couvrant de manière exhaustive les métriques système, la gestion centralisée des logs et les mécanismes d'alerting dynamique. Cette architecture de supervision est indispensable pour garantir l'observabilité totale d'un écosystème traitant plus de 180 millions de mesures par an, permettant aux équipes d'exploitation de passer d'une logique de maintenance curative à un pilotage prédictif et proactif.

A. Télémétrie et métriques système (couche prometheus & grafana)

La collecte des données de performance brute est opérée par l'utilitaire Node Exporter, déployé sous forme de démon léger sur l'intégralité des machines virtuelles et des conteneurs de l'infrastructure. Ce composant extrait en continu les indicateurs de bas niveau tels que le taux d'occupation des processeurs (CPU), la charge de la mémoire vive (RAM), les entrées/sorties disques (I/O) et le débit des interfaces réseau.

Ces données sont ensuite consommées par grattage régulier (*scraping*) par un serveur central Prometheus, qui fait office de base de données orientée séries temporelles à haute performance. Prometheus structure ces métriques avec un système d'étiquetage (*labels*) précis permettant de corréler l'état de santé de chaque micro service.

La couche de restitution finale est confiée à Grafana, qui s'interface nativement avec Prometheus pour modéliser des tableaux de bord dynamiques et interactifs mis à jour en temps réel. Ces vues décisionnelles permettent aux ingénieurs système de visualiser instantanément les goulots d'étranglement logiques, la latence des requêtes de l'API FastAPI et la charge d'ingestion sur le broker MQTT Mosquitto.

B. Gestion centralisée des logs (couche stack ELK)

Au-delà des métriques quantitatives, la compréhension fine des événements applicatifs nécessite une centralisation absolue des journaux d'événements à travers la mise en œuvre d'une stack ELK complète. Les logs générés par le serveur PostgreSQL, les conteneurs applicatifs et les pare-feu pfSense sont capturés à la source par des agents de transport légers (Filebeat). Ces flux textuels sont acheminés vers un cluster d'indexation Elasticsearch, qui structure la donnée brute pour la rendre instantanément requêtable.

L'accès à ces informations est unifié au sein de l'interface Kibana, offrant aux équipes techniques un moteur de recherche puissant pour diagnostiquer les erreurs applicatives (codes HTTP 5xx), tracer le cycle de vie d'une trame IoT corrompue ou reconstituer la chronologie d'un incident réseau.

C. Moteur d'alerting dynamique et escalade

L'intelligence de la supervision réside dans sa capacité à notifier de manière autonome les équipes d'astreinte lors du franchissement de seuils critiques préalablement définis au sein du gestionnaire d'alertes (Prometheus Alertmanager). Le système applique des règles d'évaluation strictes : si l'utilisation CPU d'un nœud applicatif dépasse 85% pendant plus de 5 minutes, ou

si le taux d'erreur de l'API REST franchit la barre des 2%, une alerte de sévérité élevée est instantanément déclenchée.

Parallèlement, les règles de corrélation de Wazuh surveillent les événements de sécurité (ex : échecs répétés de connexion SSH en zone Management). Ces alertes de sécurité et de performance sont routées vers des canaux de communication dédiés (canaux Slack techniques, notifications push WebSockets sur le tableau de bord des gestionnaires, ou messages SMS automatisés via Twilio pour les ingénieurs d'astreinte), garantissant une réduction drastique du temps moyen de résolution des incidents (MTTR).

2.4. Haute disponibilité et résilience de l'infra

L'architecture est conçue pour atteindre un objectif de disponibilité de 99,5%, s'appuyant sur plusieurs mécanismes de redondance :

Composant	Solution	Stratégie
Load Balancing	HAProxy (mode actif/passif)	Bascule automatique en cas de défaillance du nœud primaire
Base de données	PostgreSQL + réplication	Réplication synchrone pour la redondance et la cohérence des données
Sauvegardes	Backup automatisé (3-2-1)	3 copies, 2 supports différents, 1 copie hors-ligne (offline)

3. Faisabilité économique et ROI

L'analyse économique approfondie du projet EcoTrack démontre une viabilité financière incontestable, caractérisée par un retour sur investissement (ROI) positif à moyen terme pour la municipalité. Le budget initial requis pour la mise en œuvre de la plateforme est optimisé grâce à une répartition stratégique des ressources et des dépenses. Les coûts de déploiement s'articulent principalement autour de trois postes budgétaires majeurs : l'infrastructure matérielle (comprenant l'acquisition des 2 000 capteurs IoT, des serveurs de production et des équipements réseau), les licences logicielles (dont l'impact budgétaire est quasi nul en raison du choix systématique d'une stack de technologies open-source éprouvées), et enfin les ressources humaines dédiées à l'intégration technique, à l'ingénierie des flux et à la conduite du changement.

Les gains opérationnels à long terme compensent largement l'investissement technologique initial en générant des économies d'échelle substantielles dès la première année d'exploitation de la plateforme. L'introduction de la télémétrie en temps réel permet d'éliminer définitivement les tournées de ramassage inutiles et de réduire drastiquement la consommation de carburant de la flotte de bennes à ordures. De plus, l'optimisation de la planification des ressources humaines permet de réaffecter le personnel sur des zones à forte densité, réduisant ainsi les heures supplémentaires non planifiées. L'ensemble de ces optimisations logistiques permet d'estimer avec certitude une réduction globale des coûts opérationnels de l'ordre de **25% à 40%** sur les trois premières années d'exploitation du service de salubrité urbaine.

4. Faisabilité opérationnelle — organisation agile scrum

La conduite et la gouvernance du projet EcoTrack adoptent les préceptes de la méthodologie Agile Scrum, un Framework particulièrement adapté à la nature itérative, hautement technique et multidisciplinaire de cette infrastructure. Ce cadre de gestion permet de faire collaborer efficacement des experts issus de domaines variés tels que l'ingénierie réseau, la cybersécurité, le Big Data et le développement IoT, tout en garantissant une réactivité maximale face aux imprévus techniques.

4.1. Structure de l'équipe

Le product owner (PO)

Ce profil assume la responsabilité fonctionnelle stratégique du projet en portant la vision des services de la métropole. Ses missions principales englobent la définition précise des besoins, la rédaction et la priorisation du Product Backlog (gestion des *User Stories* selon la méthode MoSCoW), ainsi que la validation finale des livrables techniques lors des revues de fin de cycle.

Le scrum master (SM)

Véritable garant du respect des processus et de l'éthique Agile, il agit comme un facilitateur au quotidien pour l'équipe technique. Le Scrum Master s'assure de la bonne tenue des cérémonies, travaille activement à la levée des obstacles techniques ou organisationnels (*impédiment*), et protège la charge de travail des ingénieurs pour maintenir une vélocité constante.

L'équipe de développement (Dev Team)

Ce collectif d'ingénieurs pluridisciplinaires détient l'ensemble des compétences nécessaires pour transformer les besoins du backlog en incréments logiciels fonctionnels et sécurisés. Leurs responsabilités couvrent la conception architecturale, le déploiement des politiques de sécurité (WAF, IDS/IPS), l'intégration des flux de télémétrie IoT et la configuration des outils de monitoring.

4.2. Cérémonies agiles et rythme des sprints

La dynamique de réalisation est rythmée par des cycles de développement courts d'une durée stricte de deux semaines, appelés sprints. Chaque sprint est conçu comme un bloc de temps focalisé sur un objectif technique ou fonctionnel précis (comme la configuration initiale du réseau pfSense, le déploiement du SIEM Wazuh, l'intégration de Prometheus ou la validation industrielle des trames des capteurs IoT), évitant ainsi l'effet tunnel des projets traditionnels.

- **Le Sprint Planning (Planification de Sprint)** : Organisé au tout premier jour de chaque cycle, cet atelier permet à l'équipe de sélectionner les User Stories prioritaires du Product Backlog. Les ingénieurs découpent ces fonctionnalités en tâches techniques élémentaires et s'engagent collectivement sur un périmètre réalisable en fonction de leur capacité de production établie.
- **Le Daily Stand-up (Mêlée Quotidienne)** : Réunion synchronisée de 15 minutes maximum, tenue chaque matin debout devant le tableau de suivi des tâches (Kanban). Chaque membre de l'équipe répond à trois questions : ce qui a été accompli la veille, ce qui est planifié pour la journée, et les éventuels points de blocage qui nécessitent l'intervention du Scrum Master.
- **Le Sprint Review (Revue de Sprint)** : Cette cérémonie vient clore le sprint sous la forme d'une démonstration concrète et en direct de l'incrément logiciel développé. Elle

permet de présenter les fonctionnalités prêtes aux sponsors de la municipalité et de collecter des retours d'expérience immédiats afin de réajuster la trajectoire du projet si nécessaire.

- **Le Sprint Rétrospective (Rétrospective) :** Axée sur l'amélioration continue des processus humains et techniques, cette session réunit l'équipe Scrum pour analyser le déroulement du sprint écoulé. Elle permet d'identifier de manière transparente ce qui a fonctionné, ce qui a échoué, et de définir un plan d'action immédiat pour optimiser l'efficacité de l'équipe dès le cycle suivant.

Conclusion et recommandations

L'étude de faisabilité multi-perspectives démontre de manière univoque la viabilité technique, économique et opérationnelle du projet EcoTrack. Le stack technologique sélectionnée, reposant exclusivement sur des solutions open-source, matures, standardisées et hautement sécurisées, offre l'avantage majeur de construire une infrastructure métropolitaine robuste et hautement disponible à un coût d'acquisition logiciel nul. L'alignement rigoureux de l'architecture sur les recommandations de l'ANSSI et les obligations du RGPD confère à la plateforme la résilience indispensable à un système de gestion urbaine d'importance vitale.

Afin de maximiser les chances de succès opérationnel lors du passage en phase de réalisation active, trois recommandations clés doivent impérativement être appliquées par l'équipe projet :

- **Privilégier un déploiement itératif par phases :** Il est crucial de valider de manière isolée chaque brique technologique fondamentale (notamment l'infrastructure réseau et l'ingestion MQTT) avant d'initier les développements complexes liés au moteur d'optimisation ou à la Business Intelligence.
- **Accompagner le changement et former les équipes :** La mise en production d'outils de monitoring complexes (Grafana, stack ELK) et de détection d'incidents (Wazuh) nécessite un plan de formation rigoureux destiné aux équipes d'exploitation de la métropole, garantissant une autonomie totale lors du traitement des alertes de production.
- **Instaurer une culture de l'audit de sécurité continu :** Face à l'évolution constante des cybermenaces visant les environnements Smart City, la municipalité devra planifier des audits de sécurité réguliers, des revues de code automatisées et des tests de pénétration externes (Pentests) à chaque jalon majeur, pérennisant ainsi la confiance des administrés dans le service public numérique.

CHAPITRE 2 : Veille technologique

5. Méthodologie de veille technologique

La mise en œuvre d'une veille technologique rigoureuse s'appuie sur une diversification des sources d'information afin de garantir la pertinence et la fraîcheur des données recueillies. L'analyse des documentations officielles permet de maîtriser l'architecture des solutions, tandis que le suivi des publications des autorités étatiques et des bases de connaissances sur les cybermenaces assure une protection proactive face aux vulnérabilités émergentes. Enfin, l'inclusion de communautés techniques et de travaux de recherche académique offre une vision prospective indispensable pour anticiper les mutations des tactiques d'attaque.

5.1. Sources consultées

- Documentation officielle : pfSense Docs, Suricata User Guide, Wazuh Documentation, Elastic Docs
- Publications spécialisées : ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information), NIST Cybersecurity Framework, OWASP
- Bases de connaissances : CVE/NVD (vulnérabilités), MITRE ATT&CK (tactiques adversariales), VirusTotal Blog
- Communauté : forums GitHub, Stack Overflow, Reddit r/netsec, Hack The Box Learning
- Articles académiques et whitepapers : IEEE Xplore, ArXiv (securite IoT), Gartner Research

5.2. Outils de veille utilisés

- Agregateurs RSS : Feedly (flux sécurité), TheHive Project Blog, Krebs on Security
- Alertes automatiques : Google Alerts sur les CVE des technologies déployées
- OSINT : Shodan (exposition réseau), Censys, GreyNoise (contexte IP malveillantes)

6. Comparaison des technologies

6.1. Comparaison SIEM : Wazuh vs Splunk vs ELK Stack

Critère	Wazuh	Splunk	ELK Stack
Licence	Open-source (GPLv2)	Commerciale (couts élevés)	Open-source (Apache 2.0)
Cout	Gratuit	Très élevé (\$/GB ingéré)	Gratuit (infra à prévoir)
HIDS intégré	Oui (natif)	Non (plugin tiers)	Non (Filebeat partial)
Corrélation d'évènements	Elevée (règles MITRE ATT&CK)	Très élevée (SPL)	Moyenne (KQL)
Facilite de déploiement	Modérée	Facile (SaaS)	Complexe
Scalabilité	Bonne	Excellente	Excellente

Critère	Wazuh	Splunk	ELK Stack
Threat Intelligence	VirusTotal, MISP intégrés	Splunk (payant) SOAR	Manuelle
Conformité (RGPD, PCI)	Natif (tableaux de bord)	Natif	A configurer
Communauté	Active et croissante	Large (écosystème riche)	Très large

6.1.1. Conclusion de l'analyse comparative

Le choix d'une solution SIEM repose sur un arbitrage subtil entre le budget disponible, les compétences de l'équipe technique et les fonctionnalités de sécurité nativement intégrées au système. Wazuh se distingue comme une solution particulièrement complète en combinant les capacités d'un SIEM traditionnel à celles d'un HIDS performant, le tout adossé à des intégrations natives comme le MITRE ATT&CK, bien qu'il exige un effort initial d'optimisation des règles. De son côté, Splunk brille par sa puissance d'analyse et sa scalabilité industrielle, mais son coût prohibitif le réserve aux grandes structures. Quant à la suite ELK, elle offre une flexibilité totale pour la gestion des logs, mais nécessite un lourd travail de développement pour atteindre le niveau de sécurité opérationnel de Wazuh.

6.2. Comparaison IDS/IPS : Suricata vs Snort vs Zeek

Critère	Suricata	Snort	Zeek
Architecture	Multi-thread	Single-thread (v2) / Multi (v3)	Multi-thread
Performance	Très élevée	Modérée (v2), bonne (v3)	Très élevée
Mode IPS	Oui (natif)	Oui	Non (analyse passive)
Protocoles supportés	HTTP, TLS, DNS, SMB, SSH...	HTTP, DNS, FTP...	Etendu (logs riche)
Détection par signatures	Oui (Emerging Threats)	Oui (règles Snort)	Partielle
Analyse comportementale	Partielle	Limitée	Excellente
Extraction de fichiers	Oui	Non natif	Oui
Intégration SIEM	Excellente (EVE JSON)	Bonne	Excellente
Communauté	Très active	Historique, mature	Académique/entreprise

6.2.1. Conclusion de l'analyse comparative

L'évaluation des systèmes de détection et de prévention des intrusions réseau montre des philosophies architecturales distinctes, adaptées à des cas d'usage précis au sein du SOC. Suricata s'impose comme un choix moderne grâce à son architecture multi-thread native capable de gérer de hauts débits, complétée par un mode IPS efficace et une sortie standardisée au format EVE JSON qui facilite grandement son intégration SIEM. Snort, malgré sa position historique et la qualité de ses règles, souffre encore de limitations de performance dans sa version 2, bien que la version 3 comble ce retard. Enfin, Zeek adopte une approche totalement différente axée sur l'analyse comportementale et la génération de métadonnées réseau approfondies, ce qui en fait un outil d'analyse forensique exceptionnel mais dépourvu de capacités de blocage actif.

6.3. Comparaison pare-feu : PfSense vs FortiGate vs Cisco ASA

Critère	pfSense	FortiGate	Cisco ASA
Licence	Open-source (CE) / Payant (Plus)	Commerciale	Commerciale
Cout	Gratuit (logiciel)	Elevé (hardware+licence)	Très élevé
Interface	Web UI intuitive	Web UI + CLI avancée	CLI principalement
VPN	OpenVPN, IPsec, WireGuard	SSL-VPN, IPsec, ZTNA	AnyConnect, IPsec
IDS/IPS intégré	Via Suricata/Snort	FortiGuard (natif)	FirePOWER (module)
Haute disponibilité	CARP (actif/passif)	HA nativement	Failover actif/passif
Scalabilité	Limitée (hardware)	Excellente	Excellente
Support	Communauté + Netgate	Support professionnel	Support Cisco TAC
Conformité ANSSI	Compatible	Certifie CSPN	Certifie CSPN

6.3.1. Conclusion de l'analyse comparative

La sélection du pare-feu constitue la pierre angulaire de la sécurité périmétrique, opposant le modèle économique de l'open-source aux solutions propriétaires portées par de grands constructeurs. La solution pfSense se positionne comme un pare-feu open-source extrêmement polyvalent, offrant un catalogue de paquets additionnels très riche (comme HAProxy ou Suricata) qui permet de bâtir une appliance de sécurité sur mesure sans coût de licence. Cependant, ses limites résident dans son support commercial restreint et une scalabilité dépendante du matériel choisi. À l'inverse, FortiGate et Cisco ASA apportent des performances matérielles de pointe, des certifications rigoureuses comme la CSPN de l'ANSSI et un support d'entreprise 24/7, des atouts majeurs qui justifient des coûts d'acquisition et de licence très élevés réservés aux infrastructures de grande envergure.

7. Technologies complémentaires

7.1. Architecture zero trust

Le modèle Zero Trust (ZT) repose sur le principe fondamental : « Ne jamais faire confiance, toujours vérifier ». Contrairement aux architectures périmétriques traditionnelles qui considèrent le réseau interne comme sûr, le Zero Trust suppose que des menaces peuvent exister partout. Ainsi, aucun utilisateur, aucun équipement ni aucun flux réseau n'est intrinsèquement fiable, ce qui impose une vérification systématique et continue de chaque tentative d'accès, indépendamment de son origine géographique ou réseau.

Dans l'infrastructure ECOTRACK, ces principes théoriques se traduisent par des mesures techniques concrètes : la segmentation du réseau en 5 zones distinctes, l'obligation d'utiliser des clés pour les accès SSH, l'établissement d'un tunnel VPN pour l'accès initial, et un filtrage strict inter-zones opéré par le pare-feu pfSense.

- **Micro-segmentation** : Chaque zone réseau est isolée et les communications inter-zones sont explicitement autorisées.
- **Authentification forte** : MFA (Multi-Factor Authentication) et authentification par clé pour tous les accès.
- **Moindre privilège** : Chaque composant ne dispose que des droits strictement nécessaires à sa fonction.
- **Inspection continue** : Chaque requête est analysée indépendamment de son origine.

7.2. Sécurité IoT

La sécurité des objets connectés constitue un défi technique spécifique et complexe au sein des infrastructures modernes. Ces équipements disposent souvent de ressources matérielles limitées, tant au niveau du processeur que de la mémoire vive, ce qui restreint l'installation d'agents de sécurité traditionnels ou le chiffrement lourd. Par conséquent, la protection de ces environnements repose principalement sur des stratégies d'isolation réseau rigoureuses et sur une surveillance comportementale active aux frontières de leur zone dédiée.

- **Isolation réseau** : La zone IoT est strictement séparée du reste de l'infrastructure.
- **Protocole dédié et chiffré** : Utilisation de MQTT via Mosquitto avec authentification obligatoire des clients.
- **Surface d'attaque réduite** : Les capteurs n'ont accès qu'au broker Mosquitto, sans aucune route vers d'autres zones.
- **Surveillance** : Les flux IoT sont monitorés en permanence par Suricata pour détecter les comportements anormaux.

7.3. EDR et XDR

L'EDR (Endpoint Détection and Response) désigne les solutions spécialisées dans la détection et la réponse aux incidents directement au niveau des hôtes, tels que les serveurs et les postes de travail. L'XDR (Extended Detection and Response) pousse ce concept plus loin en étendant cette capacité de corrélation à l'ensemble de l'écosystème numérique, incluant le réseau, le cloud et les applications. Ces technologies permettent de détecter des signaux faibles et des attaques sophistiquées qu'un antivirus traditionnel ne pourrait pas identifier.

Dans notre contexte, Wazuh remplit efficacement le rôle d'EDR grâce à ses agents légers déployés sur chaque machine virtuelle. Ils collectent en continu les événements système, les alertes de sécurité et effectuent la surveillance de l'intégrité des fichiers (FIM — File Integrity Monitoring), avant de les transmettre au gestionnaire centralisé pour corrélation. L'intégration native avec l'API de VirusTotal vient enrichir ce dispositif en apportant une dimension indispensable de Cyber Threat Intelligence (CTI).

7.4. VPN et accès sécurisé

Le réseau privé virtuel (VPN) constitue le premier point d'entrée et la clé de voûte de la sécurité périmétrique de l'infrastructure ECOTRACK. En chiffrant l'intégralité du trafic entre l'administrateur et la passerelle, il assure un isolement total vis-à-vis d'Internet pour toutes les connexions de gestion et d'administration. Cette approche garantit qu'aucune interface critique n'est exposée publiquement, réduisant ainsi drastiquement les risques d'attaques par force brute ou d'exploitation de vulnérabilités sur les services de gestion.

- **Protocole** : OpenVPN (supporté nativement par pfSense).
- **Usage** : Obligatoire pour tout accès administratif initial à l'infrastructure.
- **Complément** : L'accès SSH est ensuite effectué par clé RSA de 2048 bits (authentification par mot de passe désactivée).
- **Bénéfice** : Aucun service d'administration n'est exposé directement sur Internet.

8. Choix technologiques finaux

A l'issue de la veille technologique et des comparatifs, le stack retenu pour ECOTRACK est la suivante :

Domaine	Technologie retenue	Justification principale
Pare-feu	pfSense	Open-source, flexible, supporte Suricata et HAProxy en natif
IDS/IPS	Suricata	Performances multi-thread, mode IPS, format EVE JSON pour SIEM
SIEM / HIDS	Wazuh	Solution complète open-source, MITRE ATT&CK, intégration VirusTotal
Log Management	ELK Stack (Elastic + Kibana)	Complémentarité avec Wazuh, puissance d'indexation, visualisation avancée

Domaine	Technologie retenue	Justification principale
Monitoring métriques	Prometheus + Grafana	Standard industrie, écosystème riche, dashboards temps réel
Load Balancer / WAF	HAProxy + Nginx + ModSecurity	Performance, fiabilité, protection WAF modulaire
Broker IoT	Mosquitto (MQTT)	Leger, adapte aux contraintes IoT, bien supporte
Base de données	PostgreSQL	Robustesse, réplication native, conformité ACID

9. Stack technique complete

Couche	Composants
Réseau & Périmètre	PfSense (firewall), HAProxy (LB actif/passif), Nginx (reverse proxy)
Sécurité applicative	ModSecurity (WAF), HTTPS auto-signé, VPN OpenVPN
Detection & Reponse	Suricata (IDS/IPS reseau), Wazuh agents (HIDS/HIPS hôte)
Intelligence & Correlation	Wazuh Server + VirusTotal CTI, règles MITRE ATT&CK
Monitoring métriques	Node Exporter -> Prometheus -> Grafana (dashboards temps réel)
Log Management	Elasticsearch (indexation) + Kibana (visualisation)
Transport IoT	Mosquitto MQTT Broker (zone IoT isolée)
Données	PostgreSQL (avec réplication) + backups automatisés 3-2-1

Ce stack technique constitue un écosystème cyber hétérogène à la fois cohérent, robuste et parfaitement complémentaire, où chaque brique technologique vient renforcer la posture de sécurité des autres. À titre d'exemple, les alertes réseaux levés par Suricata alimentent directement le moteur de corrélation de Wazuh, qui lui-même s'appuie sur la puissance de l'écosystème Elastic/Kibana pour centraliser et restituer graphiquement les incidents de sécurité. L'ensemble de ces flux et de ces services est orchestré et protégé de bout en bout par la segmentation rigoureuse du pare-feu pfSense, concrétisant ainsi une stratégie de défense en profondeur efficace, capable de contrer les menaces à chaque niveau de l'infrastructure.

CHAPITRE 3 : Architecture technique déployée

10. Vision globale de l'architecture

L'architecture ECOTRACK a été conçue selon le principe de défense en profondeur : chaque couche apporte sa propre protection, de sorte qu'une vulnérabilité sur un composant ne compromette pas l'ensemble du système.

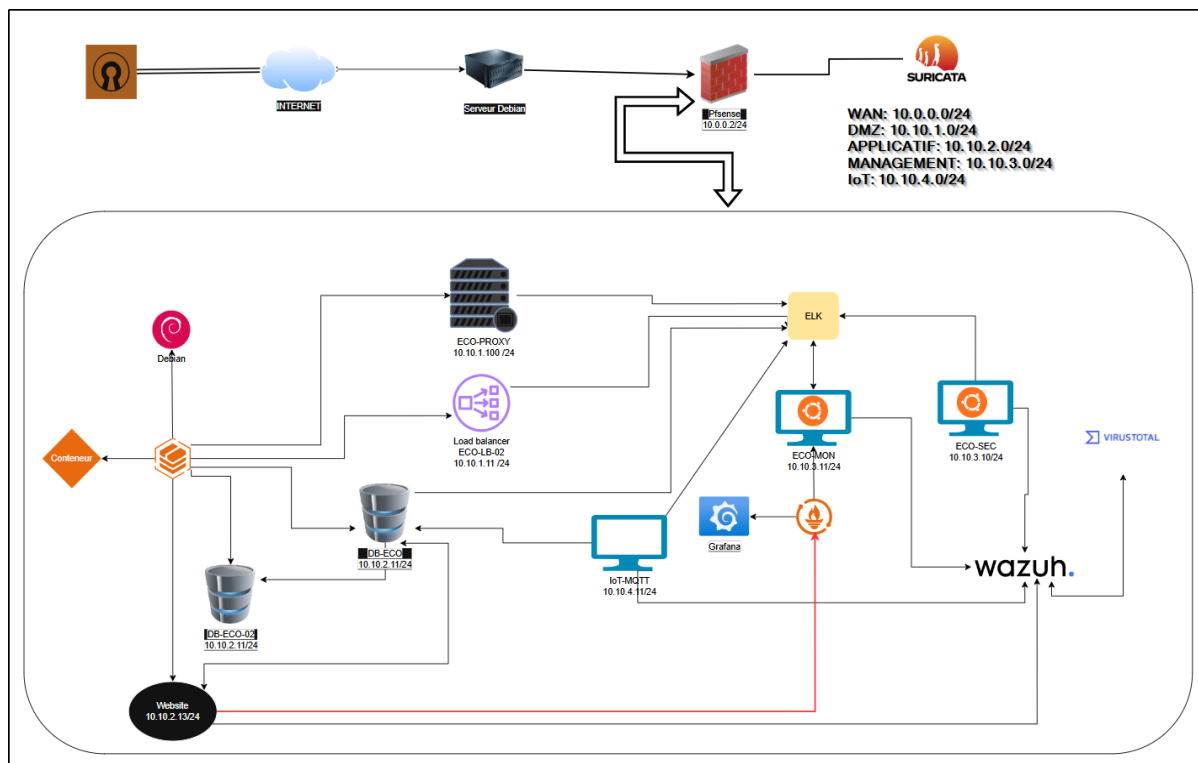


Figure 1

10.1. Topologie réseau, sécurité, monitoring

L'infrastructure ECOTRACK est structurée autour de cinq zones réseaux étanches, chacune répondant à un périmètre fonctionnel et de sécurité précis.

Zone WAN (Wide Area Network) : Point d'entrée unique vers Internet. Tout le trafic entrant transite par pfSense qui applique les règles de filtrage, les ACL et le NAT. Le VPN OpenVPN est terminé à ce niveau pour les connexions d'administration.

Zone DMZ (Demilitarized Zone) : Zone tampon entre Internet et les services internes. Elle héberge le Load Balancer HAPROXY (actif/passif) et le Reverse Proxy Nginx. Aucun service applicatif n'y est directement exposé. HAPROXY distribue les connexions entrantes et assure la haute disponibilité.

Zone APPLICATIF : Zone métier hébergeant le site web ECOTRACK et la base de données PostgreSQL avec réplication. Les accès depuis la DMZ sont strictement filtrés. La base de données n'est accessible qu'en interne.

Zone MANAGEMENT : Zone d'administration et de supervision, la plus protégée de l'infrastructure. Elle héberge le serveur Wazuh (SIEM/HIDS), la stack Prometheus + Grafana (métriques), et la stack ELK (logs). Accès uniquement par VPN + SSH clé.

Zone IoT : Zone isolée abritant le broker MQTT Mosquitto et les scripts de simulation des capteurs physiques. Cette isolation garantit que la compromission d'un capteur ne peut se propager au réseau applicatif.

11. Mesures de sécurité et conformité

11.1. Authentification, autorisation et traçabilité (AAA)

Le triptyque AAA constitue la clé de voûte de la politique de contrôle des accès au sein de l'infrastructure ECOTRACK. L'application rigoureuse de ces trois piliers garantit que chaque action effectuée sur le système est légitime, encadrée et auditable à tout moment. En combinant des mécanismes d'accès réseau étanches à une gestion fine des droits applicatifs, le système réduit considérablement le risque d'intrusion et d'élévation de privilèges, tout en assurant une visibilité totale sur l'activité des utilisateurs.

- **Authentification :** Accès initial obligatoirement via le VPN OpenVPN ; accès SSH par clé RSA 2048 bits avec désactivation complète de l'authentification par mot de passe sur le serveur principal Debian.
- **Autorisation :** Principe du moindre privilège appliqué sur chaque composant, où les droits sont accordés explicitement selon le rôle (opérateur, administrateur, auditeur).
- **Traçabilité (Accounting) :** Tous les événements d'accès et d'administration sont collectés en continu par les agents Wazuh et centralisés dans le SIEM pour audit et corrélation.

11.2. Chiffrement des communications

La confidentialité et l'intégrité des flux de données qui transitent à travers le réseau ECOTRACK sont maintenues grâce au déploiement de protocoles de chiffrement de pointe. Qu'il s'agisse de flux d'administration, de données télémétriques IoT ou d'accès aux interfaces web, chaque canal de communication est chiffré pour interdire toute interception ou modification malveillante.

11.2.1. Transport web (HTTPS)

La sécurisation des accès aux interfaces de gestion et aux applications web de la plateforme repose sur l'implémentation systématique du protocole HTTPS. Actuellement configuré avec un certificat auto-signé pour les phases de test et de déploiement initial, ce canal garantit le chiffrement des sessions des utilisateurs et des administrateurs. Pour le passage en environnement de production, une migration vers une autorité de certification reconnue, telle que Let's Encrypt, est fortement recommandée afin d'éviter les alertes de sécurité sur les navigateurs clients et de renforcer la chaîne de confiance.

11.2.2. Administration systèmes (SSH)

Les connexions dédiées à la maintenance, à la configuration et à l'administration des serveurs de l'infrastructure sont intégralement protégées par le protocole SSH. L'accès est durci par l'utilisation exclusive d'un mécanisme de chiffrement asymétrique basé sur des clés RSA d'une longueur minimale de 2048 bits. Cette configuration, combinée à la désactivation totale de l'authentification par mot de passe, immunise les serveurs contre les attaques par force brute et garantit que seuls les terminaux d'administration légitimes peuvent interagir avec le système d'exploitation.

11.2.2.3. Flux IoT (MQTT sécurisé)

Le transport des données télémétriques en provenance des objets connectés vers le broker Mosquitto fait l'objet d'une sécurisation renforcée à la couche transport. Le protocole MQTT est configuré pour exiger une authentification stricte de chaque capteur avant toute publication ou souscription à un sujet (topic). Les communications sont encapsulées dans un canal chiffré afin d'empêcher l'injection de fausses données ou l'espionnage industriel des flux logistiques au sein de la zone IoT préalablement isolée.

11.2.4. Tunnel VPN (OpenVPN)

L'accès initial à l'ensemble du périmètre technique d'ECOTRACK requiert l'établissement obligatoire d'un tunnel réseau sécurisé via la technologie OpenVPN, supportée nativement par le pare-feu pfSense. Les flux de données transitant dans ce tunnel sont chiffrés à l'aide de l'algorithme de chiffrement symétrique AES-256, reconnu pour sa robustesse face aux tentatives de décryptage. Ce mécanisme isole complètement l'infrastructure des réseaux publics en créant un canal étanche et réservé aux seuls personnels autorisés.

11.3. Conformité RGPD

L'architecture technique et logicielle d'ECOTRACK intègre nativement les exigences du Règlement Général sur la Protection des Données (RGPD) selon le principe du *Privacy by Design*. La manipulation des données numériques, en particulier celles liées à la géolocalisation ou aux profils utilisateurs, est encadrée par des barrières de sécurité strictes pour garantir le respect de la vie privée. L'infrastructure met à disposition les outils nécessaires pour auditer le traitement de ces informations et répondre efficacement aux obligations juridiques en vigueur.

Minimisation des données : Restriction stricte des données collectées aux seuls paramètres indispensables à l'exploitation (état des conteneurs et géolocalisation).

Sécurité des données : Application d'un chiffrement lourd des données en transit et au repos associé à des listes de contrôle d'accès.

Tracabilité des accès : Mise en place d'une journalisation immuable et centralisée pour l'ensemble des accès aux données personnelles.

Droit à l'effacement : Intégration de procédures documentées et automatisées permettant la purge complète des données utilisateurs sur demande.

11.4. Recommandations ANSSI

Le durcissement et l'évaluation de la sécurité du projet ECOTRACK s'alignent sur les référentiels et les guides de bonnes pratiques édités par l'ANSSI. Le respect de ces exigences étatiques permet d'élever le niveau de résilience de l'infrastructure face à des cyberattaques ciblées ou opportunistes. En adoptant ces standards nationaux, le projet démontre sa viabilité technique et facilite une éventuelle démarche d'homologation de sécurité ou de certification de type CSPN pour ses composants clés.

- **Guide de sécurisation des systèmes d'information** : Application des règles de segmentation réseau stricte et de durcissement (hardening) des systèmes d'exploitation.
- **Recommandations sur l'authentification** : Alignement sur le Référentiel Général de Sécurité (RGS) pour la gestion des accès et de l'authentification multifacteur.
- **Sécurité des systèmes industriels et IoT** : Application du référentiel de sécurité dédié aux objets connectés et aux architectures de supervision.
- **Supervision de la sécurité** : Déploiement des bonnes pratiques pour la centralisation des journaux, la détection d'anomalies et la gouvernance via un binôme SIEM/SOC.

CHAPITRE 4 : Modélisation BPMN des Flux

12. Modélisation BPMN

12.1. Introduction à la méthode BPMN

Le standard Business Process Model and Notation (BPMN 2.0) s'impose comme la méthodologie de référence internationale pour la modélisation et la formalisation des processus métier et techniques. Son objectif principal est de fournir une notation graphique normalisée, immédiatement compréhensible par l'ensemble des acteurs du projet, qu'ils soient développeurs, administrateurs système ou experts en cybersécurité. En représentant visuellement les flux d'informations, les acteurs impliqués (via des lignes de nage ou *lanes*), les événements déclencheurs et les passerelles de décision, le BPMN permet d'identifier précisément les points de pivot d'une infrastructure et d'en valider l'étanchéité logique.

Dans le cadre de l'écosystème ECOTRACK, cette démarche de modélisation a été rigoureusement appliquée à trois processus critiques qui structurent le fonctionnement de la plateforme. Elle permet de valider le comportement du système lors de la remontée des données capteurs, d'assurer le suivi des performances infrastructurelles et de garantir l'intégrité de la chaîne de transmission des alertes de sécurité vers le SOC.

12.2. Processus : Remontée IoT vers applicatif

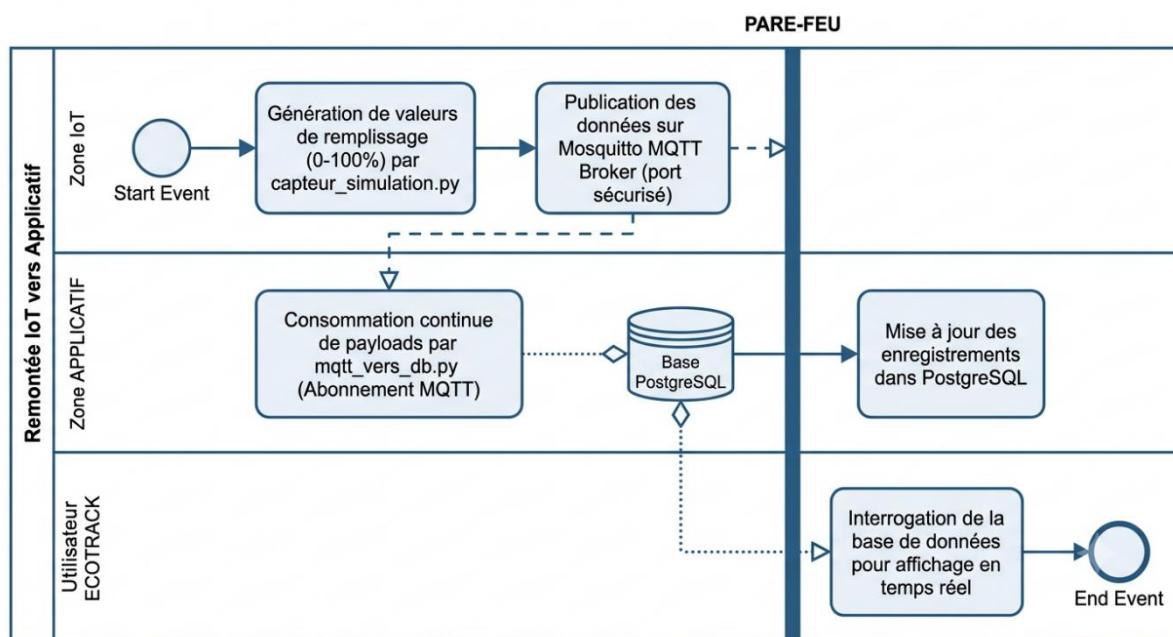


Figure 2

La cinématique d'acheminement des données issues des capteurs repose sur une architecture découplée de type publication/abonnement, garantissant une réactivité maximale et une isolation stricte des environnements. Le flux est conçu pour transporter les données de charge en quasi-temps réel depuis la périphérie du réseau jusqu'à la base de données centrale, sans jamais exposer directement les composants de stockage aux menaces issues de la zone IoT. Cette étanchéité logicielle est maintenue par des scripts intermédiaires qui agissent comme des passerelles sécurisées et contrôlées à travers le pare-feu.

- **Génération** : Le script `capteur_simulation.py` génère des valeurs aléatoires simulant l'état de remplissage des conteneurs (0-100%) à intervalles réguliers.
- **Publication** : Les valeurs mesurées sont immédiatement publiées sur le broker MQTT Mosquitto (zone IoT) via le protocole MQTT sur le port d'écoute sécurisé.
- **Consommation** : Le script `mqtt_vers_db.py` s'abonne en continu aux topics Mosquitto, récupère les payloads à chaque nouvelle publication, puis met à jour les enregistrements dans la base PostgreSQL (zone APPLICATIF).
- **Restitution** : Le site web ECOTRACK interroge la base de données à chaque actualisation de page afin d'afficher les dernières valeurs en temps réel aux utilisateurs.

12.3. Processus : remontée applicatif vers management (monitoring)

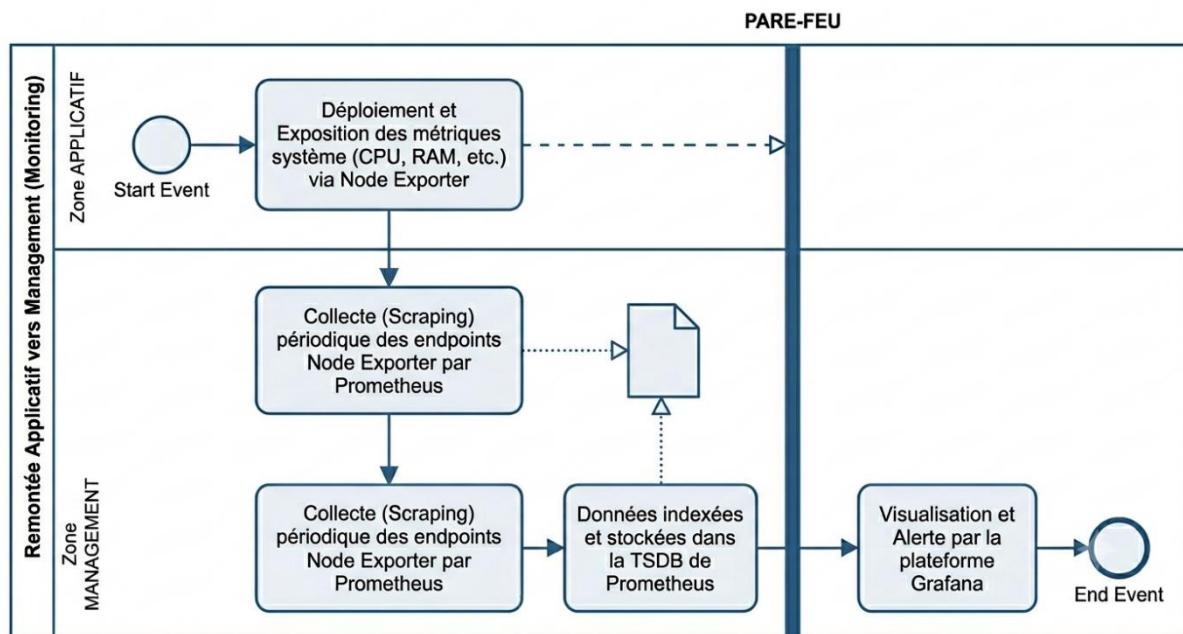


Figure 3

Le monitoring de la plateforme ECOTRACK suit un paradigme moderne basé sur la collecte passive par tirage (*pull*), où un serveur centralisé vient interroger périodiquement des agents légers. Cette méthode permet de centraliser la surveillance de la santé matérielle et logicielle de l'ensemble des machines virtuelles (serveurs web, bases de données, répartiteurs de charge) sans surcharger les composants de production. Les données temporelles ainsi accumulées offrent une visibilité historique précieuse pour le dimensionnement de l'infrastructure et la détection proactive des pannes ou des anomalies de comportement.

- **Exposition** : L'agent Node Exporter est déployé sur chaque machine virtuelle et expose les métriques système (CPU, RAM, réseau, disque) sur un endpoint HTTP dédié.
- **Collecte (Scraping)** : Le serveur Prometheus interroge périodiquement ces endpoints Node Exporter selon un calendrier et des cibles (*targets*) définis dans sa configuration.
- **Stockage** : Les données collectées sont immédiatement indexées et stockées dans la base de données temporelle de Prometheus (TSDB).
- **Visualisation et Alerte** : La plateforme Grafana interroge Prometheus via son API pour alimenter des tableaux de bord en temps réel et déclencher des alertes si des seuils critiques sont franchis.

12.4. Processus : Remontée événements vers Wazuh (SIEM)

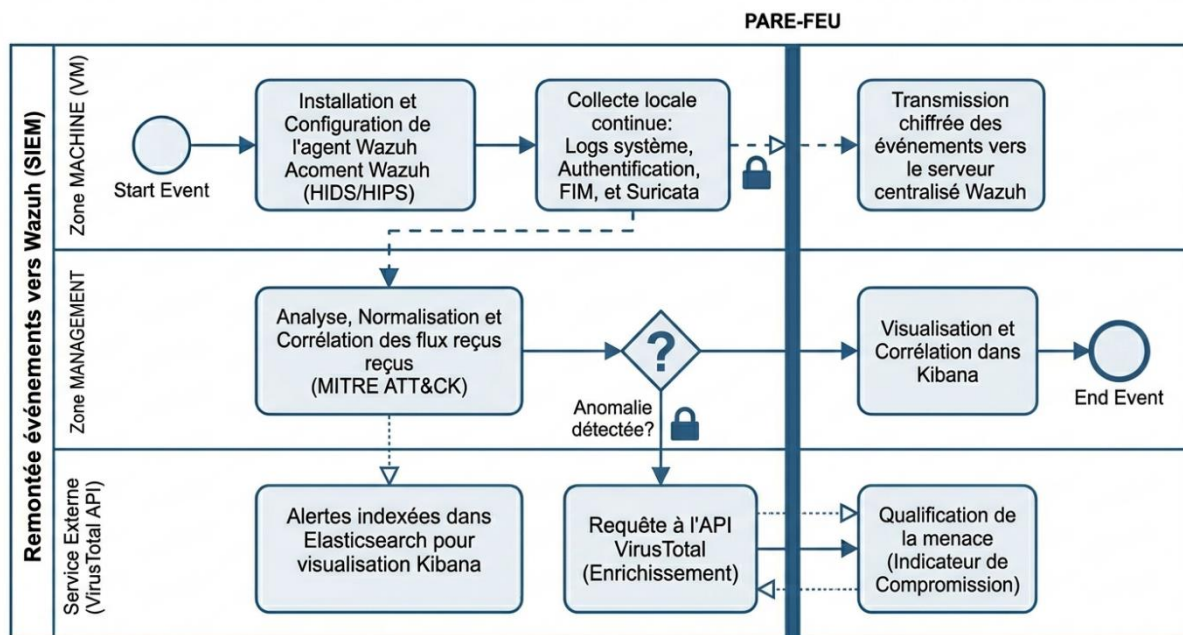


Figure 4

La détection des menaces et la centralisation des événements de sécurité s'appuient sur l'architecture robuste agent-manager de la solution Wazuh. Chaque machine virtuelle de l'infrastructure intègre un capteur logiciel qui surveille en permanence l'activité du système d'exploitation et des applications locales pour détecter toute action suspecte. Les journaux ainsi collectés subissent une transformation complète (décodage, normalisation et corrélation) afin d'offrir aux analystes une vision contextualisée des attaques, alignée sur les standards du marché.

- **Déploiement** : Les agents Wazuh sont installés sur chaque machine virtuelle de l'infrastructure pour assurer une surveillance de niveau HIDS/HIPS.
- **Collecte locale** : Chaque agent inspecte en continu les logs système (`/var/log/*`), les événements d'authentification, l'intégrité des fichiers (FIM) et les alertes générées par Suricata.
- **Transmission** : Les événements collectés sont chiffrés, puis acheminés de manière étanche vers le serveur centralisé Wazuh situé dans la zone MANAGEMENT.
- **Analyse et Indexation** : Le serveur décode et analyse les flux reçus au regard des règles MITRE ATT&CK, puis indexe les alertes dans Elasticsearch pour une visualisation dans Kibana.
- **Enrichissement (CTI)** : En cas de détection d'un fichier ou d'un indicateur de compromission (IOC) suspect, Wazuh interroge automatiquement l'API VirusTotal pour qualifier la menace.

CHAPITRE 5 : Audit initial et plan de continuité

L'implémentation d'une infrastructure d'envergure urbaine exige une analyse préalable rigoureuse des forces, des faiblesses et des risques associés à son déploiement. Ce chapitre formalise l'évaluation de sécurité de la plateforme existante, détaille les matrices d'analyse technique et structure la stratégie de résilience opérationnelle indispensable pour faire face aux sinistres majeurs ou aux tentatives de compromission.

13. Audit initial de l'infrastructure

L'audit de sécurité s'inscrit dans une démarche proactive visant à cartographier l'intégralité des actifs numériques afin d'en valider la robustesse avant l'ouverture des services aux utilisateurs. En posant des jalons de contrôle sur chaque couche technique, cette étude permet de s'assurer que les objectifs de confidentialité, d'intégrité et de disponibilité sont techniquement garantis.

13.1. Contexte et Objectifs de l'Audit

L'audit initial constitue la photographie technique de l'existant avant le déploiement définitif et valide la conformité réglementaire ainsi que structurelle de l'architecture par rapport aux objectifs de sécurité préalablement définis. Cette démarche analytique permet de détecter d'éventuels écarts de configuration, de cartographier précisément l'exposition des services et de s'assurer que chaque barrière de protection joue son rôle de manière optimale. Il couvre l'ensemble des composants de la chaîne technologique ECOTRACK, allant de la couche réseau au périmètre applicatif, en passant par les modules de monitoring et l'écosystème IoT.

13.2. Périmètre de l'audit

Domaine	Eléments audites
Contrôle d'accès	VPN OpenVPN, SSH par clé RSA 2048 bits (auth mot de passe désactivée), HTTPS
Sécurité réseau	pfSense (règles ACL, NAT), Suricata (signatures, mode IPS), segmentation 5 zones
Détection hôte	Agents Wazuh (HIDS), FIM, integration Virus Total CTI
Monitoring QoS	Prometheus + Grafana (disponibilité, latence, saturation)
Résilience	HAProxy HA, réplication PostgreSQL, backups automatisés 3-2-1

13.3. Analyse SWOT

L'évaluation d'un système d'information ne peut se limiter à une simple approche technique et doit intégrer une vision stratégique globale face à son environnement opérationnel. La matrice SWOT suivante met en relief les forces et les faiblesses intrinsèques du stack technologique, tout en identifiant les opportunités de croissance et les cybermenaces externes qui pèsent sur l'infrastructure.

	Positif	Négatif
Interne	FORCES : Stack open-source complète et cohérente ; défense en profondeur multicouche ; monitoring 360° (métriques + logs + sécurité) ; intégration CTI avec VirusTotal ; conformité ANSSI et RGPD intégrée	FAIBLESSES : Certificats HTTPS auto-signés (production) ; capacité de scalabilité matérielle limitée ; dépendance à la communauté open-source pour les correctifs critiques
Externe	OPPORTUNITES : Ecosystème IoT en expansion ; adoption croissante des standards MQTT ; évolution vers ZTNA ; potentiel d'extension à d'autres villes	MENACES : Vulnérabilités zero-day sur les composants open-source ; attaques sur les protocoles IoT (MQTT non chiffré) ; évolution rapide du paysage des menaces cyber

13.4. Identification des Risques Techniques et Organisationnels

La gestion des risques constitue le pivot central du pilotage de la sécurité, permettant de hiérarchiser les menaces selon leur vraisemblance et la gravité de leurs conséquences sur l'organisation. Ce registre répertorie les dix principaux scénarios de panne, d'attaque ou de non-conformité identifiés, tout en associant à chacun d'eux une stratégie de mitigation ciblée.

#	Risque	Probabilité	Impact	Mitigation
R01	Compromission d'un capteur IoT	Moyenne	Elevé	Isolation zone IoT, monitoring Suricata
R02	Intrusion via vulnérabilité applicative (OWASP Top 10)	Moyenne	Critique	WAF ModSecurity, HTTPS, tests de penetration
R03	Défaillance du nœud primaire HA Proxy	Faible	Elevé	HA actif/passif, bascule automatique
R04	Corruption ou perte de données PostgreSQL	Faible	Critique	Réplication + backups 3-2-1 (1 offline)
R05	Faux négatifs Suricata (menaces inconnues)	Moyenne	Moyen	Wazuh CTI VirusTotal, mise à jour signatures
R06	Accès non autorisé via SSH	Faible	Critique	Clé RSA uniquement, VPN prérequis, fail2ban
R07	Saturation du broker MQTT	Faible	Moyen	Monitoring métriques Mosquitto, QoS MQTT
R08	Dérivation de logs (log tampering)	Faible	Elevé	FIM Wazuh, logs centralisées en lecture seule

#	Risque	Probabilité	Impact	Mitigation
R09	Non-conformité RGPD	Faible	Elevé	Procédures documentées, minimisation données
R10	Disponibilité 99,5%	< Faible	Moyen	HA, monitoring proactive, alertes Grafana

13.5. Actions Prioritaires a Fort Impact

Les actions prioritaires à fort impact représentent des interventions techniques simples à mettre en œuvre mais dotées d'un pouvoir de réduction des risques immédiat. L'application de ces mesures permet de sécuriser les canaux d'administration, de chiffrer les flux les plus exposés et de dresser les premières barrières défensives indispensables avant de mener des chantiers de durcissement à plus long terme.

- Activer fail2ban sur tous les serveurs Debian pour bloquer automatiquement les attaques par force brute sur le service SSH.
- Migrer vers des certificats Let's Encrypt (via Certbot) pour éliminer définitivement les avertissements de sécurité HTTPS.
- Activer le chiffrement TLS sur les connexions MQTT pour sécuriser les échanges du broker Mosquitto à l'aide de certificats.
- Configurer des alertes Grafana et Wazuh sur les seuils critiques (CPU > 80%, échecs d'authentification répétés, stockage > 85%).
- Tester et valider le plan de bascule HAProxy ainsi que la réplication PostgreSQL en conditions réelles de panne.
- Mettre en place une rotation automatique des clés SSH et planifier une revue périodique des droits d'accès.
- Documenter et tester le processus de restauration depuis les sauvegardes pour garantir les objectifs de reprise.

14. Plan de Continuite et de Reprise d'Activité (PCA/PRA)

La pérennité des services face aux crises majeures (pannes matérielles, incendies, cyberattaques massives) repose sur une planification rigoureuse des mesures de secours. Cette section détaille la stratégie de résilience adoptée pour maintenir l'activité et restaurer l'intégrité de la plateforme ECOTRACK dans des délais maîtrisés.

14.1. Objectifs de Reprise

La définition d'indicateurs de reprise clairs est indispensable pour formaliser le niveau d'engagement de l'infrastructure face aux interruptions. Les seuils retenus ci-dessous expriment la tolérance maximale de la plateforme en matière de perte de données et de temps de coupure, traduisant ainsi des exigences de haute disponibilité en objectifs techniques mesurables.

Indicateur	Objectif	Description
RTO (Recovery Time Objective)	< 4 heures	Durée maximale acceptable d'interruption de service

Indicateur	Objectif	Description
RPO (Recovery Point Objective)	< 1 heure	Perte de données maximale acceptable (dernière sauvegarde)
Disponibilité cible	99,5%	Correspond à moins de 44 heures d'indisponibilité par an

14.2. Mécanismes Techniques

La concrétisation des objectifs de reprise s'appuie sur une redondance matérielle et logicielle systématique des composants critiques de la plateforme. En éliminer les points uniques de défaillance (*SPOF*) permet d'automatiser les processus de bascule, de sécuriser l'intégrité des bases de données et d'anticiper les dégradations de service grâce à une surveillance constante des indicateurs de performance.

- **Haute disponibilité HA Proxy** : Bascule automatique en mode actif/passif sans intervention humaine grâce à des protocoles de détection de présence.
- **Réplication PostgreSQL** : Maintien d'une base de données secondaire synchronisée, prête à être promue nœud maître en cas de défaillance du nœud primaire.
- **Backups 3-2-1 automatisés** : Conservation de 3 copies des données, sur 2 supports différents, dont 1 copie de sauvegarde stockée hors-ligne avec des tests de restauration planifiés.
- **Monitoring proactif** : Déclenchement d'alertes Prometheus et Grafana sur les indicateurs de santé système avant qu'un incident ne se déclare officiellement.

Conclusion Générale

La réussite du projet ECOTRACK ne réside pas uniquement dans sa capacité à moderniser la gestion des déchets urbains par le numérique, mais dans son aptitude à faire de la cybersécurité un accélérateur de confiance plutôt qu'un frein opérationnel. En adoptant les paradigmes du *Zero Trust* et de la défense en profondeur dès la phase de conception (*Security by Design*), la plateforme démontre qu'une infrastructure hautement sécurisée peut rester agile, performante et parfaitement adaptée aux contraintes de la *Smart City*.

Le choix stratégique d'un écosystème entièrement open-source et souverain constitue le véritable moteur de la valeur ajoutée du projet. En associant des technologies de pointe telles que pfSense, Suricata, Wazuh et la suite Elastic, ECOTRACK s'affranchit des barrières financières et contractuelles des éditeurs propriétaires tout en garantissant une maîtrise absolue de ses données et de son destin technologique. Cette approche permet de concilier une excellence technique validée par les standards de l'ANSSI avec une conformité juridique rigoureuse vis-à-vis du RGPD.

Pour transformer ce succès conceptuel en une réussite industrielle pérenne, la feuille de route s'articule désormais autour de quatre priorités majeures :

- ❖ **L'activation méthodique de l'infrastructure** : Engager une mise en production progressive et cloisonnée, en sécurisant en priorité les fondations de la zone MANAGEMENT et de la DMZ avant d'ouvrir les vannes des flux périphériques.
- ❖ **La validation de la résilience par l'épreuve** : Confronter les défenses de la plateforme à la réalité du terrain en mandatanant un cabinet d'audit indépendant pour réaliser un test d'intrusion (*pentest*) sans concession.
- ❖ **Le pilotage proactif de la menace** : Capitaliser sur la synergie entre Wazuh et Grafana pour structurer une cellule de supervision (SOC) capable de détecter et de neutraliser les signaux faibles avant qu'ils ne se transforment en crises.
- ❖ **L'ambition de la mise à l'échelle** : Exploiter la modularité intrinsèque de l'architecture pour étendre le modèle ECOTRACK à d'autres cas d'usage urbains, comme la surveillance de la qualité de l'air ou la gestion connectée de l'éclairage public.

En combinant innovation logicielle, maîtrise budgétaire et vigilance cyber de chaque instant, ECOTRACK pose les fondations d'une infrastructure urbaine résiliente, prête à relever les défis environnementaux et sécuritaires de demain.

Contribution Personnelle et Réalisation de l'Infrastructure

Bien que ce projet ait été une aventure collective menée en synergie au sein de notre groupe de cinq ingénieurs, je profite de cette conclusion personnelle pour poser un regard réflexif sur les compétences et les enseignements que cette expérience m'a apportés.

Un apprentissage forgé par la pratique

Au démarrage du projet, nous avons été confrontés à des défis techniques majeurs qui ont mis nos certitudes à l'épreuve : la mise en place d'une segmentation réseau étanche, le déploiement de notre environnement de virtualisation et la configuration fine de nos premiers outils de sécurité ont exigé une phase d'expérimentation intense, jalonnée d'essais, d'erreurs et de réajustements logiques.

Avec le recul, je mesure précisément le chemin parcouru. Si je devais réitérer ce projet aujourd'hui, je l'aborderais avec une assurance et une efficacité démultipliée : les verrous techniques d'hier, qu'il s'agisse de la maîtrise fine des permissions ou de la levée de blocages sur les terminaux, sont aujourd'hui devenus des automatismes.

L'audace technologique : de la simulation à la production

L'un des tournants majeurs de ce projet a été la transition d'un environnement de simulation local — où nous maîtrisions des outils comme VMware — vers le déploiement en production d'un hyperviseur Proxmox VE hébergé sur un serveur dédié en ligne via l'offre Hetzner. C'était une première pour notre équipe.

Nous avons délibérément choisi de sortir de notre zone de confort en optant pour Proxmox VE plutôt que de nous reposer sur des solutions d'émulation traditionnelles. Ce choix architectural s'est révélé extrêmement formateur : il nous a confrontés aux réalités concrètes des infrastructures de production et à la rigueur indispensable pour administrer un serveur exposé.

Vers une expertise durable en cybersécurité

Je suis pleinement conscient que notre architecture finale pour la plateforme n'est pas immuable et qu'elle présente encore de nombreux axes d'optimisation. C'est précisément cette perfectibilité qui fait la valeur de ce projet à mes yeux : il a agi comme un puissant catalyseur.

Plus qu'un simple livrable académique, la réalisation de l'infrastructure Cyber Ranger a été le déclencheur d'une ambition professionnelle durable. Elle m'a donné le goût de l'architecture défensive et m'incite aujourd'hui à approfondir, de manière autonome, des briques de sécurité avancées telles que le déploiement de SIEM, l'intégration d'IDS/IPS et le durcissement d'infrastructure (*hardening*).

Table des matières

SOMMAIRE	1
CHAPITRE 1 : Étude de faisabilité	2
1. Contexte stratégique et enjeux du projet ECOTRACK	2
1.1. Problématique actuelle et inefficacités structurelles	2
1.1.1. Logistique empirique et inefficacité des collectes	2
1.1.2. Surcoûts financiers et dérive budgétaire	2
1.1.3. Impact environnemental et faille de sécurité	2
1.2. Objectifs stratégiques et trajectoire de transformation	3
1.2.1. Numérisation et connectivité IoT.....	3
1.2.2. Sécurisation de l’infrastructure et défense en profondeur	3
1.2.3. Optimisation opérationnelle et planification dynamique.....	3
1.2.4. Pilotage par la donnée et aide à la décision	3
2. Faisabilité technique du projet Ecotrack	3
2.1. Architecture réseaux segmentée	4
2.2. Stack de sécurité réseaux et système	4
2.3. Monitoring avancé et supervision multi-dimensions.....	5
A. Télémétrie et métriques système (couche prometheus & grafana)	5
B. Gestion centralisée des logs (couche stack ELK)	5
C. Moteur d'alerting dynamique et escalade	5
2.4. Haute disponibilité et résilience de l’infra.....	6
3. Faisabilité économique et ROI.....	6
4. Faisabilité opérationnelle — organisation agile scrum	7
4.1. Structure de l’équipe	7
4.2. Cérémonies agiles et rythme des sprints.....	7
Conclusion et recommandations	8
CHAPITRE 2 : Veille technologique	9
5. Méthodologie de veille technologique	9
5.1. Sources consultées.....	9
5.2. Outils de veille utilisés	9
6. Comparaison des technologies	9
6.1. Comparaison SIEM : Wazuh vs Splunk vs ELK Stack.....	9
6.1.1. Conclusion de l’analyse comparative	10
6.2. Comparaison IDS/IPS : Suricata vs Snort vs Zeek.....	10
6.2.1. Conclusion de l’analyse comparative	11
6.3. Comparaison pare-feu : PfSense vs FortiGate vs Cisco ASA.....	11

6.3.1. Conclusion de l'analyse comparative	11
7. Technologies complémentaires	12
7.1. Architecture zero trust	12
7.2. Sécurité IoT	12
7.3. EDR et XDR.....	12
7.4. VPN et accès sécurisé.....	13
8. Choix technologiques finaux.....	13
9. Stack technique complete.....	14
CHAPITRE 3 : Architecture technique déployée	15
10. Vision globale de l'architecture	15
10.1. Topologie réseau, sécurité, monitoring	15
11. Mesures de sécurité et conformité.....	16
11.1. Authentification, autorisation et traçabilité (AAA).....	16
11.2. Chiffrement des communications	16
11.2.1. Transport web (HTTPS)	16
11.2.2. Administration systèmes (SSH).....	16
11.2.2.3. Flux IoT (MQTT sécurisé).....	17
11.2.4. Tunnel VPN (OpenVPN).....	17
11.3. Conformité RGPD	17
11.4. Recommandations ANSSI.....	17
CHAPITRE 4 : Modélisation BPMN des Flux.....	19
12. Modélisation BPMN	19
12.1. Introduction à la méthode BPMN.....	19
12.2. Processus : Remontée IoT vers applicatif.....	19
12.3. Processus : remontée applicatif vers management (monitoring).....	20
12.4. Processus : Remontée événements vers Wazuh (SIEM).....	21
CHAPITRE 5 : Audit initial et plan de continuité.....	22
13. Audit initial de l'infrastructure	22
13.1. Contexte et Objectifs de l'Audit	22
13.2. Périmètre de l'audit	22
13.3. Analyse SWOT.....	22
13.4. Identification des Risques Techniques et Organisationnels	23
13.5. Actions Prioritaires a Fort Impact	24
14. Plan de Continuite et de Reprise d'Activité (PCA/PRA)	24
14.1. Objectifs de Reprise.....	24
14.2. Mécanismes Techniques.....	25
Conclusion Générale	26

Table des matières.....28